

위협모델링 실무 적용

01 위협모델링 도구 활용

02 위협모델링 실무 적용 사례



학습 목표

- ✓ STRIDE 기반 위협모델링 절차를 이해한다.
- ✓ MTMT 도구를 사용하여 시스템 위협을 식별한다.
- ✓ 시스템 구성과 데이터 흐름을 시각화 할 수 있다.
- ✓ 위협에 대한 대응 방안을 도출하고 문서화할 수 있다.



학습 내용

1. MTMT 설치 및 모델 생성 방법
2. 시스템 구성요소와 데이터 흐름 다이어그램(DFD) 작성
3. STRIDE 분류체계를 활용한 위협 식별
4. 위협 별 대응 방안 도출 및 보고서 생성
5. 보안 검증 및 로그·모니터링 기반 개선 방안 수립



위협모델링 실무 적용

01 위협모델링 도구 활용

02 위협모델링 실무 적용 사례

위협모델링 도구 선정 기준

위협 모델링 도구는 자동화, 시각화, 협업 기능, 그리고 보안 프레임워크 지원 여부 등을 고려하여 선택한다.

도구를 선정할 때 고려해야 할 요소

- ✓ 자동화 지원 여부 - 위협 모델을 자동으로 생성하고, 위협을 분석할 수 있는 기능
- ✓ UI 및 사용 편의성 - 직관적인 인터페이스와 시각화 기능 제공
- ✓ 보안 프레임워크 지원 - STRIDE, PASTA, CVSS 등과 연계 가능 여부
- ✓ 협업 기능 - 여러 팀이 동시에 작업할 수 있는 기능 (DevSecOps 환경 지원 여부)
- ✓ 무료/유료 여부 - 비용 및 라이선스 정책

위협모델링 도구들

도구	주요 특징	지원플랫폼	가격
Microsoft Threat Modeling Tool	STRIDE 기반, 자동화된 위협 분석, DFD 지원	Windows	무료
OWASP Threat Dragon	웹 기반, 협업 지원, STRIDE 기반 위협 분석	Windows, Mac, Linux	무료
IriusRisk	PASTA 기반, 위협 모델링 자동화, 보안 요구사항 생성	클라우드, 온프레미스	유료
ThreatModeler	DevSecOps 연계, 위협 시뮬레이션, API 연동	클라우드, 온프레미스	유료
SecuriCAD	네트워크 모델링 및 공격 시뮬레이션	클라우드, 온프레미스	유료
CAIRIS	UX 설계 및 보안 분석 통합, CVSS 기반 평가	Linux, Docker	무료

위협모델링 도구들 - 도구 선정 가이드



무료 도구가 필요하다면?

- Microsoft Threat Modeling Tool (MS-SDL 기반, STRIDE 분석)
- OWASP Threat Dragon (웹 기반 협업 가능)
- CAIRIS (UX 및 보안 요구사항 통합 가능)



DevSecOps 파이프라인에서 사용하려면?

- ThreatModeler (CI/CD 연계, 클라우드 보안 지원)
- IriusRisk (자동 위협 모델링 및 보안 요구사항 생성)
- OWASP Threat Dragon (GitHub 연동 가능)

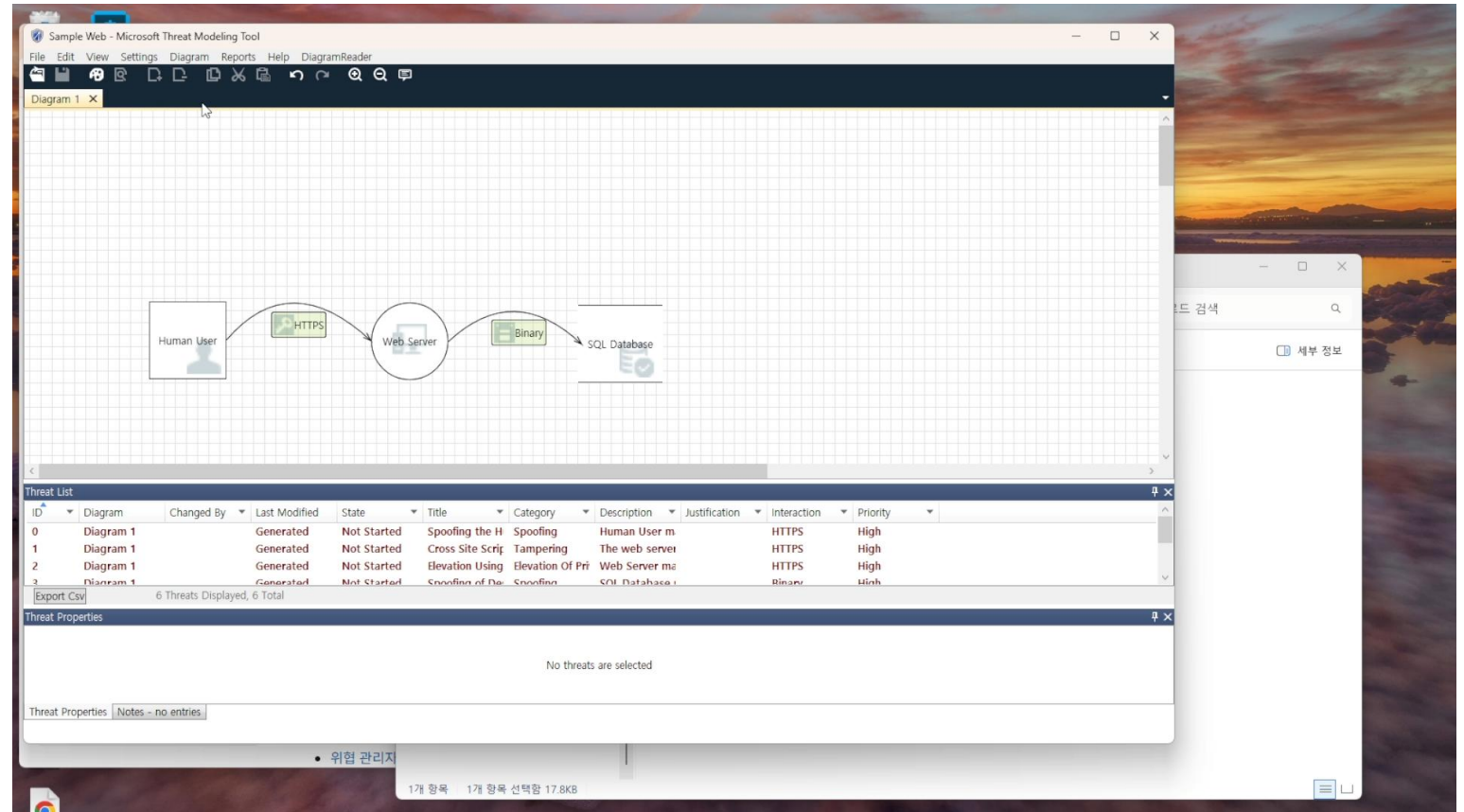


네트워크 및 인프라 보안을 강화하려면?

- SecuriCAD (공격 시뮬레이션 및 네트워크 보안 평가)
- ThreatModeler (AWS, Azure 등 클라우드 환경 지원)

MTMT(Microsoft Threats Modeling Tool)

MTMT 설치 및 실습 영상





위협모델링 실무 적용

01 위협모델링 도구 활용

02 위협모델링 실무 적용 사례

위협모델링 실무 적용 실습

서비스 시스템 전체가 아닌 웹 게시판 기능 일부를 대상으로 하여, 위협모델링 과정을 단계적으로 실습

- 대상 기능: 게시글 작성, 댓글 작성 (개별 실습)

위협모델링 분석 절차

1. 시스템 이해 및 범위 정의
2. STRIDE 위협 도출
3. DREAD 위험도 평가
4. 위협 완화 및 대응 전략 수립
5. 보안 검증 및 지속적인 개선



1단계: 시스템 이해 및 범위 정의

게시글 작성 기능으로만 범위를 정하고 이에 대한 시나리오와 관련 구성 요소를 도출한 후 DFD 작성

게시글 작성 시나리오

1. 로그인한 사용자가 게시글 작성 페이지로 이동
2. 제목, 내용, 첨부파일을 입력
3. 작성 버튼 클릭
4. 서버에서 세션 기반 인증 확인
5. 입력 값 검증 수행
6. 게시글 내용을 DB에 저장
7. 첨부파일은 파일 저장소에 저장

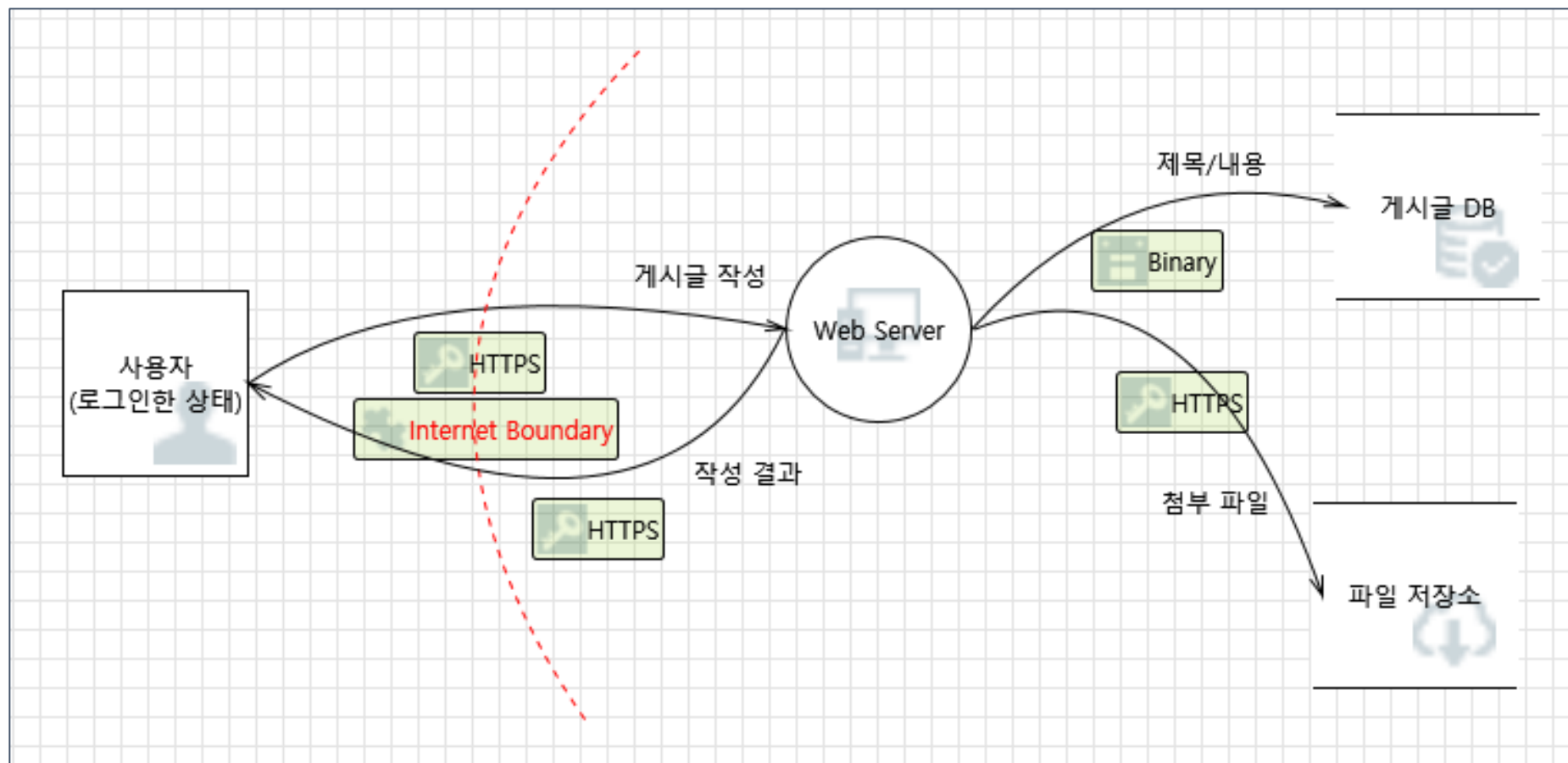
관련 구성 요소

- 사용자 (로그인 상태)
- 게시글 작성 요청 처리 서버
- 게시글 DB
- 파일 저장소



1단계: 시스템 이해 및 범위 정의 - DFD 그리기

게시글 작성 기능에 대한 DFD



2단계: STRIDE 위협 도출

게시글 작성 기능에 대한 STRIDE 위협 도출

STRIDE 요소	적용 대상	위협 예시
Spoofing (신원 위조)	게시글 작성 API	로그인하지 않은 사용자가 API를 직접 호출해 게시글 작성 가능
	세션 쿠키	세션 탈취로 타인 계정으로 게시글 작성
Tampering (데이터 변조)	게시글 입력값	게시글 제목 또는 내용에 악성 스크립트를 삽입 가능
	파일 업로드 경로	경로 조작으로 시스템 파일 덮어쓰기 시도
Repudiation (행위 부인)	로그 기록	작성자 정보가 제대로 기록되지 않으면, 작성 사실을 부인할 수 있음
	DB 트랜잭션	감사 기록이 저장되지 않아 조작 가능성 있음
Information Disclosure (정보 노출)	파일 저장소 경로	업로드된 첨부파일이 인증 없이 접근 가능한 경로에 저장되면 외부에 노출될 수 있음
	오류 메시지	서버 경로 정보가 노출되어 내부 구조 노출
Denial of Service (서비스 거부)	게시글 작성 프로세스	봇으로 대량의 게시글을 등록하여 서비스 이용을 방해할 수 있음
	본문 입력 필드	과도한 텍스트 입력으로 렌더링 지연 발생
Elevation of Privilege (권한 상승)	관리자 API	일반 사용자가 관리자 권한으로 공지사항 게시글을 등록할 수 있음
	권한 검증 로직	API 요청에 관리자 플래그 삽입 시 권한 상승 가능

3단계: DREAD 위험도 평가

게시글 작성 기능에서 도출된 위협들에 대한 위험도 평가

STRIDE	위협 내용	D	R	E	A	D	평균
S	비인증 API 호출	8	9	7	7	8	7.8
	세션 탈취 후 게시	9	9	6	8	7	7.8
T	XSS 게시	7	8	5	6	7	6.6
	파일경로 조작	9	6	6	7	8	7.2
R	사용자ID 미기록	6	7	4	6	5	5.6
	감사 로그 없음	7	7	5	6	6	6.2
I	첨부파일 노출	8	9	5	8	7	7.4
	에러에 경로 노출	5	5	3	4	6	4.6
D	게시글 폭주 등록	7	8	6	9	7	7.4
	긴 본문 처리 지연	6	7	4	6	5	5.6
E	관리자 API 호출	9	9	6	7	8	7.8
	권한 필드 조작	8	8	6	7	7	7.2

Damage (피해 규모)

Reproducibility (재현 가능성)

Exploitability (공격 가능성)

Affected users (영향 받는 사용자 수)

Discoverability (발견 가능성)

평균점수 기준

7.0 이상: 높음, 4.0~6.9:중간, 4.0 미만: 낮음

4단계: 위협 완화 및 대응 전략 수립

도출된 위협 내용들을 완화할 수 있는 대응 방안 마련

STRIDE	적용 대상	위협 내용	대응 방안
S	게시글 작성 API	비인증 API 호출	모든 요청에 대해 세션 또는 액세스 토큰 기반 인증 필수 확인
	세션 쿠키	세션 탈취 후 게시	세션에 Secure/HttpOnly 플래그 설정, 만료시간 단축 및 재생성 정책 적용
T	게시글 입력값	XSS 게시	입력값에 대한 HTML 인코딩 처리, XSS 필터 적용
	파일 업로드 경로	파일경로 조작	업로드 경로 서버 측 생성, 사용자 입력값 경로 직접 사용 금지
R	로그 기록	사용자ID 미기록	게시글 등록 시 사용자 ID 및 타임스탬프 강제 로깅
	DB 트랜잭션	감사 로그 없음	DB 레벨에서 감사 로그 저장 기능 활성화 (INSERT/UPDATE 추적)
I	파일 저장소 경로	첨부파일 노출	업로드 파일 경로에 접근 제어(ACL) 설정 및 인증 체크 적용
	오류 메시지	에러에 경로 노출	클라이언트에 전달되는 에러 메시지는 최소화, 내부 로그에만 상세 기록
D	게시글 작성 프로세스	게시글 폭주 등록	CAPTCHA 적용, 요청 속도 제한(Rate Limit), IP 기반 필터링
	본문 입력 필드	긴 본문 처리 지연	입력 글자 수 제한, 입력 값 크기 검증 및 오류 반환
E	관리자 API	관리자 API 호출	관리자 API 요청 시 별도 관리자 인증 및 권한 확인 로직 분리 적용
	권한 검증 로직	권한 필드 조작	서버 측 권한 검증은 사용자 세션 기준으로만 수행 (입력값 무시)

5단계: 보안 검증 및 지속적인 개선

- 앞 4단계 과정을 통해 수립된 대응 전략을 실제로 수행하고, 사후 테스트를 통해 검증
- 변경사항이 발생하면 위협모델링 과정이 다시 반복되어야 함
- 로그 및 모니터링 시스템을 구축하여 지속적으로 감시

[개별 실습] 댓글 작성 기능 위협모델링 분석 준비

분석 대상: 댓글 작성 기능

1. 사용자는 게시글 상세 페이지에서 댓글을 작성
2. 서버로 댓글 내용, 게시글 ID가 함께 전송
3. 서버는 로그인 상태를 확인 후, 게시글 ID의 유효성 검증
4. 댓글 내용은 댓글 DB에 저장

분석 시 주의할 점

- 게시글 ID를 참조하는 흐름 필요
- 첨부파일은 사용되지 않음
- 사용자 입력 값 처리, DB 저장, 권한 확인 등은 동일

구성 요소

- 사용자 (로그인 상태)
- 댓글 처리 웹 서버
- 게시글 DB (게시글 ID 존재 여부 확인)
- 댓글 DB

* 최종 산출물

- 시스템 개요서: 분석 대상 기초 내용, DFD
- STRIDE 위협 분석표
- DREAD 위험도 평가표
- 보안 대책 문서: 위협 완화 및 대응 방안 정리



요약 정리

- ✓ 시스템의 보안 위협을 STRIDE 기법을 활용해 식별
- ✓ MTMT 도구로 모델 작성, 위협 분석, 보고서를 생성
- ✓ 시스템 기능과 데이터 흐름을 DFD로 시각화
- ✓ 위협의 위험도를 고려해 대응 우선순위를 설정
- ✓ 보안 조치 반영 여부를 점검하고, 로그·모니터링 체계를 검토



참고 문헌

- [KISA] 소프트웨어 개발 보안 가이드(2021.12.29)
- [KISA] 소프트웨어 보안약점 진단가이드(2021)
- [에이콘출판사] 보안 위협 모델링 Threat Modeling - 위협 식별과 대응을 위한 소프트웨어 설계
- [책만] 모두를 위한 소프트웨어 보안 설계와 구현 - 취약점 분석부터 위협 모델링과 완화 전략, 보안 패턴, 암호화까지 안전한 소프트웨어의 모든 것
- Threat Modeling - <https://learn.microsoft.com/ko-kr/azure/security/develop/threat-modeling-tool>
- 보안애플리케이션 디자인 - <https://learn.microsoft.com/ko-kr/azure/security/develop/secure-design>

The background is a vibrant blue gradient. It is decorated with various abstract elements: a large solid blue sphere in the upper left, a smaller sphere with diagonal stripes in the upper right, and another striped sphere in the lower left. Several network-like structures, consisting of small dots connected by thin white lines, are scattered across the image. There are also several horizontal bars of different shades of blue and some smaller solid circles.

감사합니다.



퀴즈

1. 다음 중 위협모델링 도구 선정 기준으로 가장 적합하지 않은 것은?

- | | |
|--------------|---------------------|
| 1) 자동화 지원 여부 | 2) 보안 프레임워크 지원 여부 |
| 3) 무료/유료 여부 | 4) CWE/CVE 연계 분석 여부 |

2. 다음 중 데이터 흐름 다이어그램(DFD)의 주요 구성요소가 아닌 것은?

- | | |
|------------------------|--------------|
| 1) Process | 2) Data Flow |
| 3) External Interactor | 4) Module |

3. 다음 중 데이터 흐름 다이어그램(DFD)를 작성하는 단계는?

- | | |
|------------------------|---------------------|
| 1) 시스템 이해 및 범위 정의 | 2) 위협 식별 |
| 3) 위협 평가 및 대응 우선 순위 결정 | 4) 위협 완화 및 대응 전략 수립 |



퀴즈 정답

1. 다음 중 위협모델링 도구 선정 기준으로 가장 적합하지 않은 것은?

4) CWE/CVE 연계 분석 여부

위협모델링 도구는 소프트웨어 약점 및 취약점 목록과 직접적인 연관을 가질 필요는 없습니다.

2. 다음 중 데이터 흐름 다이어그램(DFD)의 주요 구성요소가 아닌 것은?

4) Module

DFD의 주요 구성 요소는 External Interactor, Process, Data Store, Data Flow 입니다.

3. 다음 중 데이터 흐름 다이어그램(DFD)를 작성하는 단계는?

1) 시스템 이해 및 범위 정의

데이터 흐름을 도식으로 그려보는 것은 전체 시스템의 주요 정보 흐름을 이해하기 위해 이루어집니다.